০৩/১১/২৫ · CSE · 405 · বিভাগ

L4-/T-I/CSE

Date: 06/09/2025

BANGLADESH UNIVERSITY OF ENGINEERING AND TECHNOLOGY, DHAKA

L-4/T-I B.Sc. Engineering Examinations 2023-2024

Sub: **CSE 405 (Computer Security)**

Full Marks: 210 Time: 3 Hours

The figures in the margin indicate full marks.

USE SEPARATE SCRIPTS FOR EACH SECTION

There are **FOUR** questions in this section. Question **No. 1** is **MANDATORY**.

Answer any **TWO** questions from 2, 3, and 4.

1. (a) Consider the vulnerable C program for Question 1(a). Analyze briefly whether a buffer overflow attack that invokes the hack function is possible. If possible, write pseudocode or a Python script to create the attack payload. You may use variables such as x, y, z to represent addresses (e.g., ebp, return address). Ensure these variables and defined prior to their use. Assume that you are on a 32-bit x86 little-endian system, and all the defenses are disabled. **(10)**

Vulnerable C program for Question 1(a)

```
1  #include <stdio.h>
2  #include <stdlib.h>
3  #include <string.h>
4
5  typedef struct {char name[30];} Temp;
6  typedef struct {void (*fp)();} Callback;
7  void hack() {printf("Hackerman is in action!\n");}
8  void random_print() {printf("Normally Executed!\n");}
9  void overflow_in_action(char * str){
10         Temp* data;
11         Callback* ptr;
12         char buffer[300];
13         ptr = malloc(sizeof(Callback));
14         data = malloc(sizeof(Temp));
15         strcpy(buffer, str);
16         ptr->fp = random_print;
17         strcpy(data->name, str);
18         ptr->fp();
19 }
20 int main() {
21         printf("In main function\n");
22         char str[301];
23         FILE *badfile;
24         badfile = fopen("badfile", "r");
25         fread(str, sizeof(char), 300, badfile);
26         overflow_in_action(str);
27         return 0;
28 }
```

Contd P/2

(118)

CSE 405

Contd... Q. No. 1

(b) We discussed various security principles in the class, i.e., know your threat model, security is economics, Shannon's Maxim, etc. Evaluate the principle(s) relevant to each of the following scenarios: **(10)**

(i) New cars often come with a valet key. This key is intended to be used by valet drivers who park your car for you. The key opens the door and turns on the ignition, but it does not open trunk or the glove compartment.

(ii) Even if you use a password on your laptop lock screen, there is software that lets a skilled attacker with specialized equipment bypass it.

(iii) Warranties on cell phones do not cover accidental damage, which includes liquid damage. However, many consumers who accidentally damage their phones with liquid will wait for it to dry and then claim that "it broke by itself." To combat this threat, many companies have begun to include on the product a small sticker that turns red (and stays red) when it gets wet.

(iv) Banks often make you answer your security questions over the phone. Answers to these questions are "low entropy," meaning that they are easy to guess. Some security-conscious people instead use a random password as the answer to the security question. However, attackers can sometimes convince the bank representative by claiming. "I just put in some nonsense for that question."

(v) An online retailer encrypts customer data at rest and in transit, even for internal systems, to protect against potential breaches.

(c) ARTBot joins a new local network with many users. CSBot is on the local network, but ARTBot doesn't know CSBot's phone number. ARTBot wants to learn CSBot's phone number using the following protocol: **(15)**

1. ARTBot broadcasts a request asking what CSBot's phone number is.
2. CSBot sends a response to ARTBot with its phone number, its public key, and a signature on its phone number.
3. When ARTBot receives this data, it uses the public key to verify the signature on the phone number. Then, caches the data.

Suppose you are an attacker in the local network and want to trick ARTBot into believing CSBot's phone number is a value set by you. Now organize the attack if you are an (i) on-path attacker, (ii) man-in-the-middle attacker, and (iii) off-path attacker. Also, analyze a possible defense against the above attack.

Contd P/3

(119)

CSE 405

2. (a) Recall that DHCP (Dynamic Host Configuration Protocol) is responsible for setting up configurations when a computer first joins a local network. Suppose that Alice wants to connect to a local network. You are also part of the local network. You want to supply Alice with a forged configuration, making you the man-in-the-middle attacker. Assume that your computer has an IP address 10.10.10.32, and the network router and the DHCP server have an IP address 10.10.10.4. There are no other machines on the network, and there are no reserved or private IP addresses. When Alice broadcasts a request for a configuration to everyone, what values of the assigned IP address and the router's IP address could you include in your response to Alice? Imagine that you supply the correct router's IP address in your forged configuration offer to Alice. How would you still become a man-in-the-middle attacker? **(10)**

(b) Consider the vulnerable C program for Question 2(b). What input do you have to provide on lines 12 and 4 in order to execute a SHELLCODE of length 31? Assume that you are on a 32-bit x86 little-endian system, ASLR is enabled, and all other defenses are disabled. **(10)**

Vulnerable C program for Question 2(b)

```
1  void hack() {
2      char buf[8], input[9];
3      int i;
4      fread(input, 9, 1, stdin);
5      for (i = 8; i >= 0; i--) buf[i] = input[i];
6      return;
7  }
8  void main() {
9      char simple[32];
10     // Prints out the 4-byte address of simple
11     printf("%p", &simple);
12     fgets(simple, 32, stdin);
13     hack();
14     return;
15 }
```

(c) Suppose that a client connects to a server, and the then performs the TCP handshake and initial data transfer according to the Figure for Question 2(c). Suppose you are an off-path attacker. Now answer the following questions: **(15)**

(i) Can you do anything malicious to the connection? If so, what can you do?

(ii) The client starts getting responses from the server that don't make any sense. Inferring that you are attempting to hijack the connection, the client then immediately sends the server a RST packet, which terminates the ongoing connection. You want impersonate the client by establishing a new connection. How would you do this?

Contd P/4

(120)

CSE 405

Contd... Q. No. 2(c)

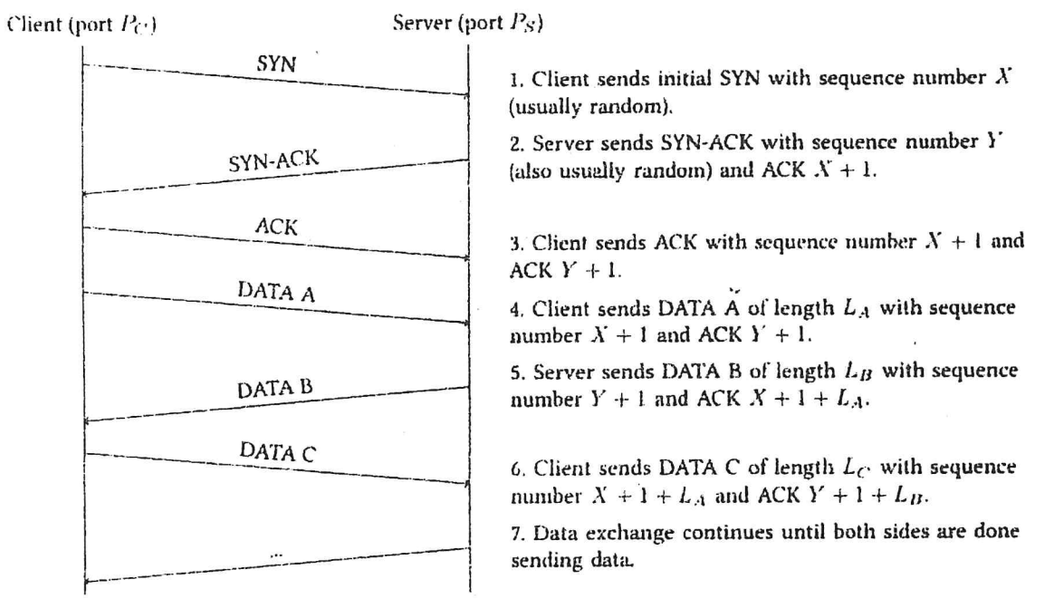


Figure for Question 2(c)

3. (a) You are assigned to protect the network of KobulBot's hidden server farm. All incoming network requests are processed by a network-based intrusion detection system (NIDS) and firewall. External users are restricted to accessing the server via HTTPS. Now, assess whether the following attacks can always be prevented under this configuration, assuming the attacker is on the path. **(10)**

1. RST Injection Attack
2. Reflected XSS attack
3. SYN Flooding Attack
4. DNS Spoofing Attack
5. DDoS Attack

(b) Did the Code Red worm take advantage of zero-day vulnerabilities? How did this worm spread? **(5)**

(c) Suppose there is an attacker in the BUET network and all the machines in the BUET use the same DNS recursive resolver, which is also a machine inside the BUET network. The attacker wants to poison the recursive resolver's cache using the Kaminsky attack for the domain **www.cse.buet.ac.bd**. Assume that the resolver does not use source port randomization, so the attacker will likely to succeed. The attacker has constructed a website with lots of images as follows: **(20)**

<img src = "http://fake1.buet.ac.bd">, <img src = "http://fake2.buet.ac.bd">,
<img src = "http://fake3.buet.ac.bd">, <img src = "http://fake4.buet.ac.bd">,

Contd P/5

(12)

CSE 405

Contd... Q. No. 3(c)

Now, answer the following questions:

i. If the attacker can send multiple responses which use each possible transaction id, why would the attacker want to load many, even thousands of images on his/her website rather just a few?

ii. Can the attacker poison the resolver's cache for the domain **www.google.com** with the constructed website, and why?

iii. Can DNS over TLS defend against the Kaminsky attack, and why?

iv. How does the DNSSEC protocol defend against the Kaminsky attack?

4. (a) JULY and PROTIDHONI are services provided by some servers. For every UDP packet arriving at port 36, JULY sends back a packet with 36 to 360 random characters. For every UDP packet arriving at port 5. PROTIDHONI sends back a packet with the same content. GENZ wants to perform a DoS attack on two servers. One with IP address X that supports JULY, and another with IP address Y that supports PROTIDHONI. Now, answer the following questions: **(10)**

i. Is it possible to create a single UDP packet with no content that will cause both servers to consume a large amount of bandwidth? If possible, write the source IP, destination IP, source port, and destination port of the attack packet.

ii. Assume now that JULY and PROTIDHONI are modified to only respond to TCP packets (post-handshake) and not UDP. Is it possible to create a single TCP SYN packet with no content that will cause both servers to consume a large amount of bandwidth? Assume GENZ is off-path from the two servers. If the attack is possible, write the source IP, destination IP, source port, destination port, sequence number, and the acknowledgement number of the attack packet.

(b) Recall the stateful packet filters, which are a type of firewall that keeps track of inbound/outbound connections. Some smart firewalls can also decode the application layer. Supported a company has placed a smart stateful firewall in its network. It has the following rules: **(10)**

1. Deny packets that contain the sequence of bytes a, d, m, i, n.
2. Allow all other packets.

Mallory wants to evade the firewall rule and send packets containing the word "admin". Mallory thought that if the packet has the word "admin". it will be filtered. So she divided the packets into 5 different packets, each containing a byte a, d, m, i, n, respectively, and then sent them out of order. Will Mallory be successful in evading the firewall rule? If not, design a strategy that is guaranteed to work.

Contd P/6

CSE 405

Contd... Q. No. 4

(c) Recall the transport Layer Security (TLS) protocol, which is a protocol for creating a secure communication channel over the internet. Now, answer the following questions based on the Figure for Question 4(c). **(15)**

i. ClientHello and ServerHello are not encrypted or authenticated. Explain why a man-in-the-middle cannot exploit this. Consider both the Diffie-Hellman and RSA cases.

ii. Note that in the TLS protocol, there are two cipher keys C_b and C_s. One key is used only by the client, and the other is used only by the server. Likewise, there are two integrity keys I_b and I_s. Alice proposes that both the server and the client should simply share one cipher key C and one integrity key I. Why might this be a bad idea?

iii. The protocol given in the figure is a simplified form of what actually happens. After step 8 (ChangeCipherSpec), the protocol as described is still vulnerable. What is the vulnerability, and how could you fix this?

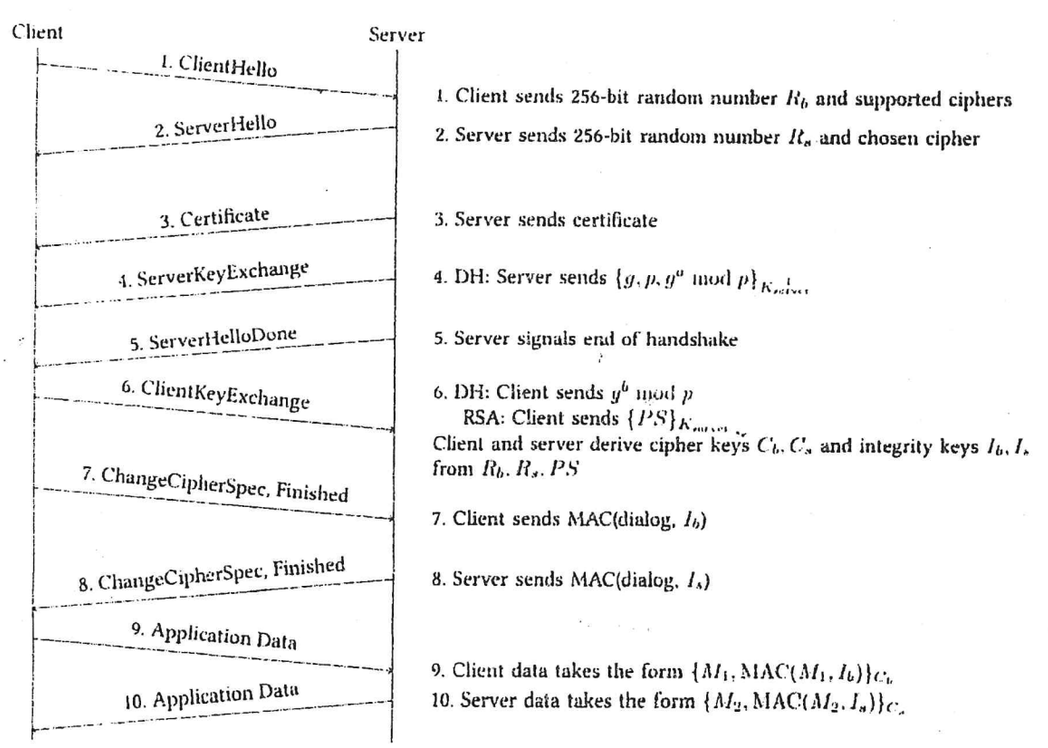


Figure for Question 4(c)

123

CSE 405

SECTION – B

There are **FOUR** questions in this section. Answer any **THREE** including **Question 5.**

5. **[MANDATORY]**

(a) Briefly explain any three of the following concepts. Use diagrams where appropriate to support your explanation: **(3×5=15)**

i. The CIA Properties of Cryptography

ii. Confusion and Diffusion

iii. Message Authentication Code (MAC)

iv. Homograph Phishing Attack

v. Clickjacking

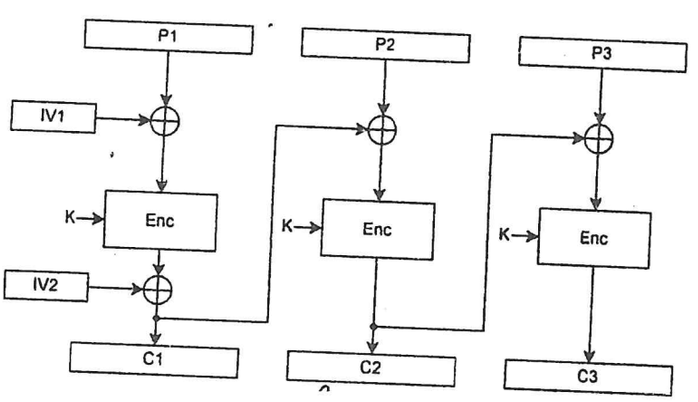


Figure for Q 5(b)

(b) Consider the block cipher encryption diagram in the Figure for Q 5(b). Answer the following questions. **(10+10=20)**

(i) Analyze the encryption and decryption processes by deriving the equations for the first three blocks. Draw and label the decryption block diagram clearly. Determine whether encryption, decryption, or both operations can be parallelized.

(ii) You are Mallory. Design a ciphertext modification attack, where you know the first two plaintext-ciphertext pairs but do not possess the secret key. You intercept the ciphertext consisting of IV_1, IV_2, C_1, C_2. Describe and evaluate a strategy to alter these components such that Bob decrypts the modified ciphertext as (P_1', P_2') instead of the original (P_1, P_2). Justify your design using appropriate equations and reasoning.

Contd P/8

CSE 405

6. (a) In Diffie-Hellman, both parties agree on a large prime p and a primitive root g modulo p. Alice picks a secret a and sends $A = g^a \bmod p$; Bob picks a secret b and sends $B = g^b \bmod p$. Both compute the shared secret key $K = g^{ab} \bmod p$, with Alice computing $B^a \bmod p$ and Bob computing $A^b \bmod p$. **(10+5=15)**

Assume you are Mallory. You know for certain that there are no trusted third parties available to verify identities of Alice or Bob. How can you leverage this fact to successfully execute a Man-in-the-Middle (MITM) attack? Provide an explanation with a timing diagram to illustrate the attack steps. In addition, **briefly** explain a defense mechanism against such MITM attacks.

(b) Suppose a cryptosystem encrypts plaintext letters $A = 0$, $B = 1,\ldots, Z = 25$ to ciphertext using the transformation in Figure for Q. 6(b): **(20)**

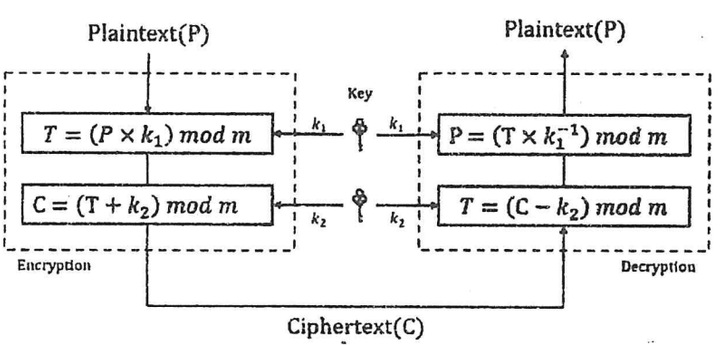


Figure for Q. 6(b)

were $M = 26$ and K_1 is an integer coprime to 26. P and C represents the plaintext and ciphertext letters, respectively.

Given the following encryption mappings:

- Plaintex letter 'B' encrypts to ciphertext letter 'E'
- Plaintex letter 'E' encrypts to ciphertext letter 'P'

Set up and solve the system of simultaneous congruences modulo 26 to determine the values of K_1 and K_2.

7. RSA Encryption and E1Gamal Encryption are two fundamental public-key cryptosystems. In RSA, a user selects two large primes p and q, computes $N = pq$, and then calculates $\phi(N) = (p - 1)(q - 1)$. The public exponent e is chosen such that $\gcd(e, \phi(N)) = 1$, and the private exponent d is computed as $d = e^{-1} \bmod \phi(N)$. Encryption of message M is done as $C = M^e \bmod N$, and decryption as $M = C^d \bmod N$.

Contd P/9

125

CSE 405

Contd... Q. No. 7

In ElGamal, a large prime p and generator g are publicly known. Bob selects a private key b and computes public key $B = g^b \bmod p$. To encrypt a message M, Alice picks random r, computes $R = g^r \bmod p$, and $C = M \cdot B^r \bmod p$. She sends ciphertext (R, C). Bob decrypts using $M = C \cdot R^{-b} \bmod p$.

(a) Consider an ElGamal encryption scheme over Z^*_{353}, where the prime $p = 353$ and the generator $g = 3$. Bob selects his private key $b = 233$. Alice wants to send a message $M = 123$ to Bob. She picks a random key $r = 97$. Compute Bob's public key, the ciphertext sent by Alice, and show how Bob uses his private key to recover the original message step by step. Is the scheme IND-CPA secure and non-malleable? Justify briefly with appropriate reasoning. **(10+5=15)**

(b) Prove the correctness of RSA encryption. Show mathematically why decryption of ciphertext yields the original message using number theoretic reasoning and necessary theorems. **(10)**

(c) Define how RSA digital signatures are created and verified. Use the notation Sign(d, M) and Verify(e, N, M, sig). Suppose Alice encrypts a message M with Bob's RSA public key and also sends a digital signature of M using her own private key. Can both the ciphertext and the signature be sent together securely? Justify your answer from a cryptographic security perspective. **(10)**

8. (a) What is authenticated encryption? Between MAC-then-encrypt and encrypt-then-MAC, which is preferable and why? Justify from a security standpoint. **(5)**

(b) The following cookies are all set by login.moodle.com: **(10)**

Cookie 1	Cookie 2	Cookie 3
name = theme	name = auth	name = file
value = dark	value = ok	value = secret
domain = moodle.com	domain = long.moodle.com	domain = moodle.com
path =/	path =/test	path =/ print
secure = true	secure = false	secure = true

For each of the following URLs, determine which cookies will be sent by the browser in the corresponding HTTP request.

(i) http://print. moodle.com/print

(ii) http://login. moodle.com/

Contd P/10

CSE 405

Contd... Q. No. 8(b)

(iii) http://moodle.com/test

(iv) https://moodle.com/print/test

(v) https://login. moodle.com/test/print

You are required to fill in the following matrix in your answer script. For each cell, write 1 if the corresponding cookie will be sent, and 0 otherwise. No explanation is needed.

URLs	Cookie 1	Cookie 2	Cookie 3
(i)			
(ii)			
(iii)			
(iv)			
(v)			

(c) A web application provides the following login functionality. The backend code handing uses the following logic: **(10)**

```
$query = "SELECT * FROM users
WHERE username = '$username' AND password = '$password' " ;
```

Suppose the table contains the following entry:

id: 1, username: alice, password : password123

Identify whether this login form is vulnerable to SQL injection. If so, give a concrete input for the username and password fields that would allow a user to log in as alice without knowing her password. Explain how prepared statements can help prevent such attacks.

(d) What is a Cross-Site Scripting (XSS) attack? **Briefly** explain the difference between Stored and Reflected XSS, using diagrams to illustrate both. **(10)**

L-4/T-1/CSE

Date : 18/04/2024

BANGLADESH UNIVERSITY OF ENGINEERING AND TECHNOLOGY, DHAKA

L-4/T-1 B. Sc. Engineering Examinations 2022-2023

Sub : **CSE 405** (Computer Security)

19 Batch

Full Marks : 210 Time : 3 Hours

The figures in the margin indicate full marks.

USE SEPARATE SCRIPTS FOR EACH SECTION

SECTION – A

There are **FOUR** questions in this section. Question No. 1 is **MANDATORY**.

Answer **Q. No. 1** and **TWO** other Questions.

1. (a) Differentiate between "principle of least privilege" and "Separation of privilege" in computer security domain. Why is compromise recording so important? Give examples to explain. **(10)**

   (b) Explain SYN flooding attack (with figure). Evaluate the application of SYN-Cookie to prevent such DDoS attacks. **(12)**

   (c) How can an attacker launch DHCP starvation attack? Explain with respect to message flow diagram. Analyze its relation to the DHCP spoofing attack. **(13)**

2. (a) Consider a password policy that requires uppercase, lowercase, numeric and special characters. The minimum password length is 10 characters. In addition, users are forced to change their passwords every month. At least how many passwords per second should an attacker brute force to crack a user credential? Show necessary calculations. **(12)**

   (b) Dr. Shams believes that all the effort spent on access control matrices and access control lists is a waste of time. He believes that all file access permissions for every file should be restricted only to the owner of that file. Describe at least two scenarios where he is wrong, that is, where users other than a file's owner need some kind of allowed access privileges. **(12)**

   (c) Formulate the steps to follow if a hacker wants to access and exploit a target system through scanning the OS/Application version of the system. **(11)**

3. (a) Explain MAC flooding attack with necessary topology diagram. Identify its impact on a switch. What are the benefits for an attacker in this attack? **(12)**

   (b) List the main features of rootkits. How does a kernel-level rootkit hide itself? Explain with respect to function hooking. **(12)**

   (c) Explain the working process of an adware (with a figure). Also, explain why it is often beneficial for an adware author to include spyware in his adware. **(11)**

Contd P/2

CSE 405

4. (a) What is DNS chache poisoning? How can it be exploited by the attacker? Write three defense mechanisms to prevent/mitigate such attack. **(12)**

(b) Examine the necessity to use a honeypot system by an organization (using a topology diagram). How much overhead does it add to the original network? **(10)**

(c) Compare stateful and stateless firewalls. **(7)**

(d) What is zero-day attack? Why is it so dangerous? **(6)**

SECTION – B

There are **FOUR** questions in this section. Question No. 5 is **MANDATORY.**

Answer **Q. No. 5** and **TWO** other Questions.

5. (a) Electronic Code Block (ECB), Cipher Block Chaining(CBC), Counter (CTR) are three popular modes of operations for block ciphers. Compare these modes, in terms of the following three properties using necessary figures. **(12)**

(i) Security in terms of IND_CPA property

(ii) Performance in terms of parallelization of encryption and decryption process

(iii) Robustness in case of incorrect usage of IV/nonce

(b) Alice and Bob want to communicate with confidentiality and integrity using a Symmetric encryption scheme (Encryption: Enc(K, m) and Decryption: Dec(K, c)), Cryptographic hash function: Hash(m), and Message Authentication Code: MAC(K, m). They share a symmetric key K and know each other's public key. We assume these cryptographic tools do not interfere with each other when used in combination; i.e., we can safely use the same key for encryption and MAC. Assume that, Alice sends the messages to Bob using the following three schemes. **(12)**

1. $C = C_1, C_2$; where $C_1 = Enc(K, m)$ and $C_2 = Hash(C_1)$
2. $C = C_1, C_2$; where $C_1 = Enc(K, m)$ and $C_2 = Mac(K, m)$
3. $C = C_1, C_2$; where $C_1 = Enc(K, m)$ and $C_2 = Mac(K, C_1)$

Based on the above description answer the following questions.

(i) Consider an eavesdropper Eve, who can see the communication between Alice and Bob. Evaluate which scheme(s), provide confidentiality against Eve.

(ii) Consider a man-in-the-middle attacker Mallory, who can eavesdrop and modify the communication between Alice and Bob. Evaluate which scheme(s), provide integrity against Mallory.

(c) Analyze the effectiveness (or drawbacks) of cookie policies in addressing the following issues. **(11)**

(i) Preventing CSRF attacks

(ii) Preventing session hijacking through XSS

(iii) Confidentiality of stored cookies

Contd P/3

CSE 405

6. (a) Explain Diffie-Hellman key exchange algorithm and its security flaw against MITM adversary with necessary figures. Modify this algorithm using RSA based digital signature to circumvent the mentioned flaw. **(10+5=15)**

(b) Alice likes to use a startup, WorstBUY, to do her online shopping. Whenever she adds an item to her cart a POST request containing the field 'item' is made. On receiving such a request, WorstBUY executes the following statement: **(6+4=10)**

```
cart_add := fmt.sprintf ("INSERT INTO cart (session, item) "
+ "values ('%s', '%s')", sessionToken, item)
db.Exec(cart_add)
```

Each item in the cart is stored as a separate row in the cart table. Alice is in desperate need of some pens, but the website blocks her from adding more than 3 units to her cart.

(i) Describe a POST request she can make to cause the `cart_add` statement to add 100 units of pens to her cart.

(ii) What preventive measure could be taken to prevent Alice from performing SQL injection?

(c) Describe how HMAC-DRBG algorithm generates pseudorandom numbers and explain how it ensure security and rollback-resistance provided that HMAC is a secured cryptographic hash function. **(5+5=10)**

7. (a) A common CSRF defense is to place a token in the DOM of every page (e.g. as a hidden form element) in addition to the cookie. An HTTP request is accepted by the server only if it contains both a valid HTTP cookie header and a valid token in the POST parameters. One approach in choosing a CSRF token is to choose one at random and refresh it upon each POST request. **(10+5=15)**

(i) Explain how this method can guarantee protection against CSRF attempts without depending on browser supports.

(ii) Argue the merit or demerit of refreshing the token only on POST requests instead of both GET and POST requests.

(b) "TOR network can ensure the anonymity of both the client and the server" – justify or refute this argument with necessary figures and explanations. You need to give a brief overview of the cryptographic approach adopted by TOR network in preserving anonymity. **(13)**

(c) Briefly explain how reflected XSS attack differs from stored XSS attack. **(7)**

Contd P/4

CSE 405

8. (a) A Message Authentication Code (MAC) consists of two algorithms (S, V). Algorithm S(k, m) uses a secret key k to generate an integrity tag 't' for a message 'm'. Algorithm V(k, m, t) uses a secret key k to validate a given integrity tag 't' for message 'm'. Recall that a cryptographic hash function h is a non-keyed function that outputs a short hash h(m) for an input message 'm'. The function is said to be collision resistant if it is extremely difficult to find two distinct messages m_0, m_1 such that $h(m_0) = h(m_1)$. Let us consider three approaches for providing file integrity for a single file F on disk. The file system should be able to detect any unauthorized modification to this file. We say that the system is secure if an attacker cannot modify F without being detected. You can assume that the owner of the file F has a key 'k' known to the system, but not to the attacker. **(5+5+5=15)**

Integrity Protection Method: Compute an integrity tag for the file F and store the integrity tag in the header of F. Upon file open, the file system checks that the integrity tag is valid. For each of the following approaches, explain if the resulting system is secure or not.

(i) The integrity tag is computed using a collision resistant hash function applied to F. Validation of the integrity tag upon file open is done by rehashing the file and comparing the result to the value in the header of F.

(ii) The integrity tag is computed as the MAC of F using the user's key 'k' as the MAC secret key.

(iii) The integrity tag is computed in the same approach as described in (i), but it is stored in Read Only Memory which the attackers can read but not modify.

(b) Do you consider SMS based two factor-authentication to be effective preventive measure against phising attack? Justify your answer. **(8)**

(c) Describe the process of how adversaries could perform clickjack attack in the context of following two cases: **(6+6=12)**

(i) The not so popular e-commerce website WorstPay is sponsoring Eve's personal blog in return of placing their jPhone advertisement in her website as iframe. Eve will only be paid if users click on the buy button of the iframe which automatically redirects them to WorstPay. But no one is interested in clicking the advertisement. So, Eve has decided to clickjack her visitors with a fake click button to win free Getflix subscription.

(ii) Result of a public examination has just been published. Eve has rendered an iframe of the official result's website in her personal website. When anyone fill up the information and hits the submit button, Eve wants them to get redirected to her twitter page in the first click, her facebook page in the second click and fetch the result (the intended operation) on the third click.

L-4/T-1/CSE Date : 30/10/2023

BANGLADESH UNIVERSITY OF ENGINEERING AND TECHNOLOGY, DHAKA

L-4/T-1 B. Sc. Engineering Examinations 2021-2022

Sub : **CSE 405** (Computer Security)

18 Batch

Full Marks : 210 Time : 3 Hours

The figures in the margin indicate full marks.

USE SEPARATE SCRIPTS FOR EACH SECTION

SECTION – A

There are **FOUR** questions in this section. Answer any **THREE**.

1. (a) Illustrate the relationship among "information security", "cyber security" and "information technology security" using a Venn diagram. **(5)**

   (b) Write the requirements for biometric identification and describe the process of biometric identification. Discuss the challenges of privacy preserving in biometric data. **(3+4+3=10)**

   (c) Given the key 'GYBNQKURP' and the plaintext 'ACT', judge the authenticity of hill cipher by performing encryption and decryption. **(10)**

   (d) Why is the Ceasar cipher a symmetric encryption algorithm? Suppose you encrypt using an affine cipher, then encrypt the encryption using another affine cipher (both are working on mod 26). Is there any advantage to doing this, rather than using a single affine cipher? Explain with necessary derivation. **(4+6=10)**

2. (a) Categorize the security attacks in relation to security goals C.I.A. **(5)**

   (b) Explain the application of elliptical curves in cryptography. Find the elliptical group of points E_{11} (1, 6). Note that E_{11} (1, 6) is the elliptical curve $y^2 = x_3 + ax + b$ (mod 11) with $a = 1$ and $b = 6$. **(4+6=10)**

   (c) Explain the philosophy behind Diffie-Hellman key exchange protocol. In the Diffie-Hellman key exchange protocol, let the prime number be 353 and one of its prime root is 3. Let the users A and B select their secret keys 97 and 233, respectively. Compute the public keys of A and B and also their common secret key. **(3+7=10)**

   (d) After studying your system a cryptanalyst told you that your system is secure for short message only, it is vulnerable for long message due to its mode of operation. Write the name of the operation mode of your encryption system and describe its operation. How can you overcome this problem? Explain. **(10)**

3. (a) How does DLL injection posses high security risks? **(5)**

   (b) Demonstrate all possible usages of a hash function for authentication, confidentiality and digital signature. **(10)**

Contd P/2

CSE 405

Contd ... Q. No. 3

(c) Briefly explain the desired properties of a cryptographic hash function. Suppose a message m is divided into l blocks $M_1, M_2, \ldots, M_l$ of 160 bits each. Let $h(x) = M_1 \oplus M_2 \oplus \ldots \oplus M_l$ be a hash function. Evaluate the hash function in terms of the desired properties. **(5+5=10)**

(d) Compare symmetric key cryptography and public key cryptography. How is the use of private and public keys in digital signatures different from that in public key cryptography? Explain. **(5+5=10)**

4. (a) How can the virtual memory or swap partition be the target of attackers? Explain. **(5)**

(b) Describe how a message authentication code is created by HMAC. **(10)**

(c) Explain the attack to which DES is vulnerable. **(5+5=10)**

A friend of yours comes up with a brilliant idea to increase the key length of 3DES. He proposes 5DES, where he uses five DES keys (k_1, k_2, k_3, k_4, k_5) to encrypt a message block m_i as follows:

$$c_i \leftarrow E_{k_5}\left(D_{k_4}\left(E_{k_3}\left(D_{k_2}\left(E_{k_1}\left(m_i\right)\right)\right)\right)\right)$$

This construction uses $5 \cdot 56 = 280$ random bytes, so he claims that the security of 5DES is better than AES-256. Justify his claim by computing the effective key-length (strength) of 5DES.

(d) For each of the following elements of DES, choose the comparable element in AES or explain why it is not needed in AES: **(10)**

(i) XOR of subkey material with the input of the f function,

(ii) XOR of the f function output with the left half of the block,

(iii) the f function,

(iv) permutation P, and

(v) swapping of halves of the block.

SECTION – B

There are **FOUR** questions in this section. Answer any **THREE**.

5. (a) Examine the financial benefits for a malware designer to create lots of different malicious code instances that exploit the same vulnerability of a popular software yet have different malware signatures. **(12)**

(b) Distinguish between IPSec Authentication Header (AH) and Encapsulating Security Protocol (ESP) along with their encapsulations. **(12)**

(c) Formulate the process to take down the Command & Control (C&C) server of a botnet. **(11)**

Contd P/3

CSE 405

6. (a) To defend against optimistic TCP ACK attacks, it has been suggested to modify the TCP implementation so that data segments are randomly dropped by the server. Examine how this modification allows one to detect an optimistic ACK attacker. **(12)**

   (b) Design three defense mechanisms that can be used to prevent/mitigate DNS cache poisoning attack. **(12)**

   (c) Examine (with a topology diagram) the necessity to use a honeypot system by an organization. Does it hamper the normal operation of the organization? **(11)**

7. (a) Explain the process to defend against SYN flooding attack using SYN cookie. **(12)**

   (b) Differentiate between click-jacking and phishing with examples. **(12)**

   (c) Examine why it is a bad idea to purchase from a shopping web site that uses a self-signed SSL server certificate. **(11)**

8. (a) Identify possible vulnerability in the following SQL statement regarding privilege delegation: **(12)**

   GRANT SELECT ON employees TO Alice with grant option;

   How to revoke such access from Alice when she leaves the organization so that the risks can be minimized?

   (b) Formulate the steps to follow if a hacker wants to access and exploit a target system through scanning the OS version of the system. **(12)**

   (c) Alice has a whitelist solution to her spam problem: she only accepts emails from people who are in her address book. All other emails are rejected. Is this an effective way to block spam? Justify your answer. **(11)**

L-4/T-1/CSE Date : 25/09/2022

BANGLADESH UNIVERSITY OF ENGINEERING AND TECHNOLOGY, DHAKA

L-4/T-1 B. Sc. Engineering Examinations 2020-2021

Sub : **CSE 405** (Computer Security)

17 Batch

Full Marks : 210 Time : 3 Hours

The figures in the margin indicate full marks.

USE SEPARATE SCRIPTS FOR EACH SECTION

SECTION – A

There are **FOUR** questions in this section. Answer any **THREE**.

1. (a) What was the main vulnerability of WannaCry attacks? Why was it successful? Was it a zero-day attack? Why or why not? **(12)**

   (b) Suppose an Internet service provider (ISP) has voice over IP (VoIP) telephone system that it manages and sells. Suppose further that this ISP is deliberately dropping 25% of the packets used in its competitors' VoIP system when those packets are going through this ISP's routers. What kind of an attack is this? **(12)**

   (c) Why is compromise recording so important in computer security? What tools are used for such purpose? **(11)**

2. (a) What is role-based access control? Explain with a figure. What are its benefits and drawbacks? **(12)**

   (b) Consider the following security measures for airline travel. A list of names of people who are not allowed to fly is maintained by the government and given to the airlines; people whose names are on the list are not allowed to make flight reservations. Before entering the departure area of the airport, passengers go through a security check where they have to present a government-issued ID and a boarding pass. Before boarding a flight, passengers must present a boarding pass, which is scanned to verify the reservation. Show how someone who is on the no-fly list can manage to fly provided boarding passes can be printed online. Which additional security measures should be implemented in order to eliminate this vulnerability? **(12)**

   (c) Why should the forensic investigator make two copies of a digital evidence? What precautions are needed for this purpose? How is chain of custody maintained? **(11)**

3. (a) Why would it be bad to mix the stack and heap segments of memory in the same segment? Give one illustrative example how this mixture can be manipulated. **(12)**

   (b) How can you find out the vulnerabilities of a popular Web Server? How such vulnerabilities can be exploited? Give step by step approaches that can be followed with required tools you may use. **(12)**

   (c) Explain epidemic model for worm propagation with necessary figure. **(11)**

Contd P/2

CSE 405

4. (a) Explain possible ways how ARP spoofing can be prevented. Also, list the methods how a network administrator can monitor the network to identify the attacking host in the internal network. **(12)**

   (b) Why is it beneficial for an attacker's perspective to install an agent in the victim PC inside the corporate network? What methods can be used for such task? How can a network administrator prevent such intrusion attempt? Can the firewall help? Why or why not? **(12)**

   (c) What is base-rate fallacy? Explain with an example. How does it impact the incident handlers in their day-to-day activities? **(11)**

SECTION – B

There are **FOUR** questions in this section. Answer any **THREE**.

5. (a) Bob created a web app for a free streaming service. Eavesdropping is not an issue in this case. Therefore, he decides to use UDP and hence, cannot use TLS (and HTTPS). However, he needs to ensure data integrity, so that any other person cannot **impersonate** the sender and **alter** or **replay** his messages. How can you achieve this using Cookies? Explain your construction. **(15)**

   (b) Bob is writing a web server in C++. To avoid SQL injection attacks, he ensures one query statement runs exactly one SQL query in the database. Alice mentions that people can still do SQLi attacks with this, like changing password for everyone. Perform this attack in the following html form in Bob's website. How does the attack work? **(10)**

Old Password	
New Password	

(c) Briefly describe four countermeasures against return-to-libc vulnerability. **(10)**

6. (a) In a social network website NS (`networksocial.com`), Trudy wants to make as many friends as possible. To do this, he needs to create a malicious website which he plans to name `trudymalicious.com`. This website should do the following once a person A enters: **(15)**

   (i) Send a friend request to Trudy (in NS)

   (ii) Set the homepage of A (in NS) such that any user visiting that page sends a friend request to trudy (in NS).

Contd P/3

CSE 405

Contd ... Q. No. 6

Explain how Trudy can create this website in order to execute the attacks. Assume NS doesn't have security measures for CSRF or XSS.

The following GET request sends a friend request to Trudy.

```
http://www.networksocial.com/action/friends/add?friend=20
```

(b) Explain the Elgamal Signature Scheme. Why shouldn't you reuse the same random number, k, on two different signatures? **(10)**

(c) Using diagrams, show how you can figure out the placement of the argument for `system()` function while performing the return-to-libc attack. **(10)**

7. (a) Bob created a cipher that first applies a Caesar cipher and then a Hill cipher over the plaintext to get the ciphertext, which he calls a *CH network*. He thinks that if a substitution-permutation network satisfies Shannon's confusion and diffusion properties, so should a CH network. However, Alice mentions that it is very easy to break this cipher. Explain how a CH network can be broken. **(15)**

(b) The following cookies are all set by *docs.example.com*:

Cookie 1	Cookie 2	Cookie 3
name=file	name=file	name=file
value=main	value=test	value=print
domain=.example.com	domain=docs.example.com	domain=.example.com
path=/	path=/test	path=/print
secure	non-secure	secure

For each of the following URLs list which cookies are available. **(10)**

(i) http://print.example.com/print

(ii) https://docs.example.com/

(iii) http://example.com/test

(iv) https://example.com/print/test

(v) https://docs.example.com/test/print

(c) What is StackGuard? Describe how it counters buffer overflow attacks. Use diagrams where necessary. **(10)**

8. (a) In the following C program try.c, figure out which attacks you can perform. Briefly explain how the attacks work in this program. Write down any assumption about the environment that you need to make to perform these attacks. **(15)**

CSE 405

Contd ... Q. No. 8

```
#include <stdio.h>
#include <unistd.h>

int main() {
   char *fn = "tmp/XYZ";
   char buffer[60];
   FILE *fp;

   scanf("%s", buffer);

   fp = fopen(fn, "a+");
   if (!access(fn, W_OK))
      fwrite(buffer, sizeof(char), strlen(buffer), fp);
   else
      printf("No permission");
   fclose(fp);

   return 0;
}
```

(b) 'A b-bit hash function provides b/2-bit security' – prove this statement. **(10)**

(c) Bob created a website where the authentication cookie expires after 1 year. If a user changes the password, it is updated in the database. Alice told Bob that while resetting the password he should reset the authentication cookie too. Explain the reason behind this suggestion. **(15)**

BANGLADESH UNIVERSITY OF ENGINEERING AND TECHNOLOGY, DHAKA

L-4/T-1 B. Sc. Engineering Examinations 2019-2020

Sub: **CSE 405** (Computer Security)

16 Batch

Full Marks: 210 Time: 2 hours and 30 minutes

USE SEPARATE SCRIPTS FOR EACH SECTION

The figures in the margin indicate full marks.

SECTION – A

There are **FOUR** questions in this section. Answer any **THREE**.

1 (a) How does digital signature ensure non-repudiation? Explain with a figure. **(12)**

(b) What is Heartbleed bug? Explain briefly. What can be its major consequences? **(12)**

(c) During the 2008 U.S. Presidential campaign, hackers were able to gain access to an email account of Vice Presidential candidate, Sarah Palin. Their attack is said to have involved tricking the mail system to reset Sarah Palin's password, claiming that it was really Palin who had forgotten her password. The system asked the hackers a number of personal questions regarding Palin's identity, including her birthday, zip code, a few personal security question—all of which the hackers were able to answer using data available on the Internet. What kind of attack was it? Also, what degree of security is provided by a password reset feature such as this? **(11)**

2 (a) How does a botnet work? Draw a diagram showing its different components. How is it used to launch DDoS attacks? **(12)**

(b) What is the number of 10-character passwords that could be constructed from a character set that includes all 128 characters in the ASCII character set. How long, on average, would it take an attacker to guess such a password if he could test a password every microsecond? **(12)**

(c) Consider that you have just got a call from the University Hall administrator, who notified that either you or your roommate is issuing denial-of-service attacks against other students from your shared network segment. You know you are not doing this, but you are unsure about your roommate. How can you tell if this accusation is true or not? And if it is true, what should you do about it? **(11)**

3 (a) List three major reasons why ransomware attacks have increased significantly during the COVID-19 pandemic. **(12)**

(b) How is encrypted virus formed by the attackers? How can you detect encrypted virus? Explain briefly. **(12)**

(c) Alice, who uses a version of Unix, requires a better program to manage her photos. She wants Bob to code this program for her. However, she does not want Bob to be able to see some confidential files that she has in her account (for example, the solutions of some homework). On the other hand, Bob wants to make sure that Alice does not read his code, since this will probably be his CSE406 final project. Explain how this can be achieved by using the *setuid* and *chmod* functions provided by UNIX. Also, regardless of real systems' behavior, assume that a user cannot revert to the real UID after using the effective UID that was set by the setuid feature. Specifically consider the fact that Bob could embed code in his program to transfer data (it has access to), to a public folder or a web server. **(11)**

4 (a) Explain using necessary diagram to show how DNS spoofing can be used to launch man-in-the-middle attack. **(12)**

(b) Why would a hacker want to make a network switch act like a hub? How can such attack be launched? What is the name of the attack? How can you protect against such attack? **(12)**

(c) To defend against optimistic TCP ACK attacks, it has been suggested to modify the TCP implementation so that data segments are randomly dropped by the server. Explain with necessary examples to show how this modification allows you to detect an optimistic TCP ACK attacker. **(11)**

BANGLADESH UNIVERSITY OF ENGINEERING AND TECHNOLOGY, DHAKA

L-4/T-1 B. Sc. Engineering Examinations 2019-2020

Sub: **CSE 405** (Computer Security)

16 Batch

Full Marks: 210 Time: 2 hours and 30 minutes

USE SEPARATE SCRIPTS FOR EACH SECTION

The figures in the margin indicate full marks.

SECTION – B

There are **FOUR** questions in this section. Answer any **THREE**.

5. (a) What is a Protocol-based Intrusion Detection System (PIDS)? What are the conditions for alarm sounding by an intrusion detection system? Explain how the effectiveness of an IDS can be misinterpreted due to the Base-Rate Fallacy. **(14)**

   (b) What are the possible fields that should be included in an audit record of an event for IDS data collection? Explain how a statistical intrusion detection system works. Mention one potential weakness of statistical methods of intrusion detection. **(14)**

   (c) Explain why the honeypot computer is an effective tool for intrusion detection. **(07)**

6. (a) Explain how the pad P is used directly for both encryption and decryption in a binary one-time pad cryptosystem. What is a transposition cipher? Explain why a transposition cipher is actually a special case of a Hill cipher. **(14)**

   (b) What are the desirable properties of an ideal cryptographic hash function? Distinguish between weak and strong collision resistance properties. Demonstrate that the hash function, $H(x) = (5x + 11) \bmod 19$, is not weakly collision resistant for H(4). Draw a block diagram of the Merkle-Damgard construction, and explain why it is important for a compression function to have strong collision resistance for the Merkle-Damgard construction. **(21)**

7. (a) What is Euler's Totient Function, and Euler's Theorem in Modular Arithmetic? Explain how the modular inverse can be calculated using the Euler theorem. **(08)**

   (b) Find the solutions to following modular equations: (i) $x^8 \equiv 9 \pmod{13}$ (ii) $x^2 \equiv 2 \pmod{13}$ **(12)**
   Also, find the value of $3^{128} \bmod 7$.
   (You may use the Modular Exponentiation Table for n = 13 provided in the next page of the question paper.)

   (c) Let p = 83, q = 101, n = pq, and also e = 3, d = 5467 for an *RSA cryptosystem A*. Also, let p = 17, q = 11, n = pq, and also e = 7, d = 23 for another *RSA cryptosystem B*. Assume, symbols have their usual meanings. Calculate phi (n) and phi (phi (n)) for both systems, and explain why both systems are valid RSA cryptosystems. For *RSA cryptosystem B*, find the ciphertext C, if the plaintext M is 3. **(15)**

8. (a) Describe the encryption and decryption method of the Elgamal cryptosystem. Prove the correctness of the Elgamal decryption method. Provide one illustrative example to show that digital signatures can be susceptible to a birthday attack. **(20)**

   (b) Write the steps of the Diffie-Hellman key exchange protocol. Explain how it is vulnerable to a man-in-the-middle attack, if the attacker can intercept and modify the messages, by showing the steps of the attack. **(15)**

	y											
	1	2	3	4	5	6	7	8	9	10	11	12
1^y	1	1	1	1	1	1	1	1	1	1	1	1
2^y	2	4	8	3	6	12	11	9	5	10	7	1
3^y	3	9	1	3	9	1	3	9	1	3	9	1
4^y	4	3	12	9	10	1	4	3	12	9	10	1
5^y	5	12	8	1	5	12	8	1	5	12	8	1
6^y	6	10	8	9	2	12	7	3	5	4	11	1
7^y	7	10	5	9	11	12	6	3	8	4	2	1
8^y	8	12	5	1	8	12	5	1	8	12	5	1
9^y	9	3	1	9	3	1	9	3	1	9	3	1
10^y	10	9	12	3	4	1	10	9	12	3	4	1
11^y	11	4	5	3	7	12	2	9	8	10	6	1
12^y	12	1	12	1	12	1	12	1	12	1	12	1

Table for Q(7): Modular Exponentiation Table for n = 13

L-4/T-1/CSE Date : 24/10/2019

BANGLADESH UNIVERSITY OF ENGINEERING AND TECHNOLOGY, DHAKA

L-4/T-1 B. Sc. Engineering Examinations 2018-2019

Sub : **CSE 405** (Computer Security)

15 Batch

Full Marks : 210 Time : 3 Hours

The figures in the margin indicate full marks.

USE SEPARATE SCRIPTS FOR EACH SECTION

SECTION – A

There are **FOUR** questions in this Section. Answer any **THREE**.

1. (a) What are the key information kept in a digital certificate? Explain the role of Certification Authority (CA) with necessary figure. **(9)**

   (b) Distinguish between IPSec ESP and AH protocol. Compare the two encapsulations using their header formats **(9)**

   (c) Suppose the author of an online banking system has programmed in a secret feature so that the program emails him the account information for any account whose balance has just gone over 5,000 USD. What kind of attack is this and what are some of its risks? **(9)**

   (d) Explain the risks to Bob if he is willing to sign a seemingly random string using his private key. **(8)**

2. (a) Explain briefly the differences between polymorphic viruses and metamorphic viruses. Give two examples of each type. **(7)**

   (b) Explain why it is often beneficial for an adware author to include spyware in his adware. **(8)**

   (c) What is function hooking mechanism used by rootkits? Why is it very dangerous for the system? Give three examples that can be used by this mechanism to avoid rootkit detection? **(12)**

   (d) Why could the Morris Worm spread be so fast? What was its consequences? **(8)**

3. (a) Give examples of easter eggs and a logic bomb. **(6)**

   (b) How can a hacker perform complete session hijacking attack on TCP? Explain with a diagram. **(9)**

   (c) What is optimistic TCP ACK attack? How to prevent or mitigate this attack? **(10)**

   (d) How botnets are created and controlled? What can be done using botnets? **(10)**

4. (a) Why is subdomain DNS Cache poisoning used against a DNS server? Why is it more successful than other Cache poisoning attacks? **(10)**

   (b) Distinguish pharming and phishing attacks. Give examples to explain. **(8)**

   (c) Describe the types of rules that would be needed for a rule-based intrusion detection system to detect ARP spoofing attack. **(9)**

   (d) Explain few use-Cases of honey pots for intrusion detection in a system (using necessary figure(s)). **(8)**

Contd P/2

CSE 405

SECTION – B

There are **NINE** questions in this section. Answer any **SEVEN**.

5. (a) Consider the plaintext P=**DITECTIVE**. Convert **P** to corresponding ciphertext **C** using hill cipher, with block size m=3 and key **(12)**

$$K = \begin{bmatrix} 3 & 0 & 2 \\ 2 & 0 & 2 \\ 0 & 1 & 1 \end{bmatrix}$$

(b) Suppose that a message has been encrypted using DES in ciphertext block chaining mode. An extra 0 bit is inserted into the ciphertext stream after block C_i. How much plaintext will be garbled as a result? **(3)**

6. (a) Consider the following P-box and S-box. **(8)**

(i) If the 8 bits are designated from top to bottom as 01234567 in P-box, what is the output of this particular P-box?

(ii) If eight octal numbers 76543210 are input one after another in S-box, write down the output sequence.

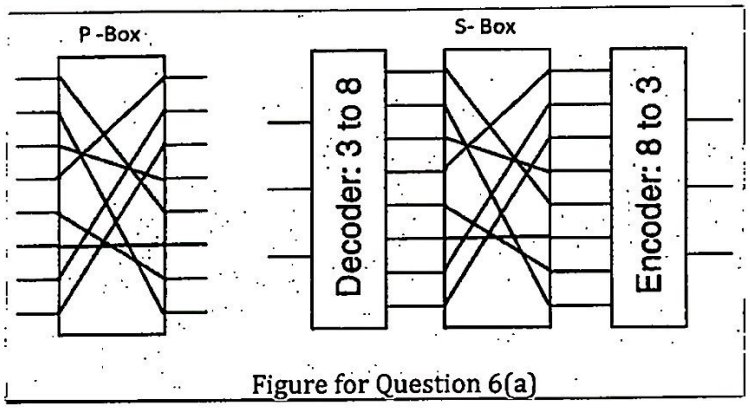


Figure for Question 6(a)

(b) Draw a cross section diagram of a Pin Tumbler Lock identifying its various parts. **(7)**

7. (a) Suppose you have a lock L_1 with 5 pins which is opened by key K_1. The height of driver pin is 5 units and the height of key pins are 2, 4, 5, 2, and 6 respectively. If you add three master wafers (master pin) in any of the three pins in L_1, then how many additional keys are possible theoretically that will open lock L_1? **(3)**

(b) Consider another lock L_2 which is opened by key K_2. The height of driver pin is same as L_1 and the height of key pins are 4, 2, 5, 5, and 6 units respectively. Draw a sample lock L_3 identifying only driver pins, master wafers and key pins with appropriate heights so that L_3 will be opened by both key K_1 and K_2. Also draw the figure demonstrating (identifying appropriate shear line) how K_1 will open L_3. **(12)**

Contd P/3

CSE 405

8. (a) Write down the name of characteristics for a good biometric authentication technology including the features that are desirable but not absolutely necessary. **(6)**

   (b) Write short notes on the following terms (any three). **(9)**

   (i) Faraday Cage

   (ii) Blind SQL injection

   (iii) Impersonation token

   (iv) Homograph attack

9. (a) Consider the following C code vulnerable to Format String attack. **(12)**

```
int main(){
   char user_input[100];
   int secret1; //assume appropriate value is assigned.
   char secret2[10]; //assume appropriate value is
assigned.
   char secret3[10]; //assume appropriate value is
assigned.
   gets(user_input);
   printf(user_input);
}
```

Assume that following addresses (32bits) have been calculated using gdb.

- Start of printf() internal pointer is 0xaabbcc20
- Address of secret1 is 0xaabbcc34 (resides in same stack frame of printf())
- Address of secret2 is 0xaabbcc38 (resides in same stack frame of printf())
- Address of secret3 is 0x11223344 (resides in different stack frame)
- Address of user_input[] is 0xaabbcc50 (resides in same stack frame of print())
- Integer takes 4 bytes
- You do not need to consider buffer overflow or other attacks
- Hexadecimals characters are 0, 1, ... 9, a, b, c d, e, f.

Now, for each of the following cases, construct the user_input to perform each of the following tasks. You cannot perform any other changes to the program.

(i) Print the value of secret1

(ii) Modify the value of secret1

(iii) Print the value of secret2

(iv) Print the value of secret3 (Hints: In C language, \x10 in a string tells the compiler to put a hexadecimal value 0x10 in the current position. The value will take up just on byte. In printf() \x is considered as an escape character, so print() will ignore \x10 and proceed to next characters)

(b) Write down full form of the following terms. **(3)**

(i) ICCID (ii) IMSI (iii) ASLR

Contd P/4

CSE 405

10. Consider the following C code snippet. **(15)**

```
main(){
   int a=3;
   foo(a);
   int b=4;
   return 0;
}
```

```
void foo(int p){
   char str[100];
   /*necessary
code to read str
from a sample.txt
file, assume no
buffer overflow
attack will occur
here/
   bar(str);
   int c=p;
   return;
}
```

```
void bar(char *s){
   char buf[10];
   strcpy(buf,s);
   return;
}
```

Assume the following information.

- Address of first instruction *(int a=3;)* for main() is 0x41424347. For foo() and bar(), first instruction's address are 0x11223344 and 0x111223355 respectively (All are 32 bits address space).
- Each instruction takes one byte and instructions are placed sequentially in address space for same function. For example, address of second instruction for function foo() and bar() will be 0x11223345 and 0x11223356 respectively.
- Order of local variables in stack will be according to their declaration. For example, a will be placed before (higher address in stack) b in main() function.
- Address of stack frame pointer for main(), foo() and bar() are 0xaabbccdd, 0xaabbddcc and 0xaaccbbdd respectively.
- Assume any return address for main function.
- Integer takes 4 bytes

Now answer the following questions.

(i) Write down the stack frames for all three functions mentioning appropriate address and values for each content (return address, stack frame pointer, local variables, parameters etc.)

(ii) Write down the content for sample.txt file using English alphabets only so that the function bar() returns to main() function directly with the help of buffer overflow.

11. (a) Consider the following sample form and corresponding php code for password change of an employee. Construct corresponding input for the form so that you can change the password to *"you_are _hacked"* and salary to 10$ for employee "EID100" without knowing his old password. **(5)**

Contd P/5

CSE 405

Contd. ... Q. No. 11

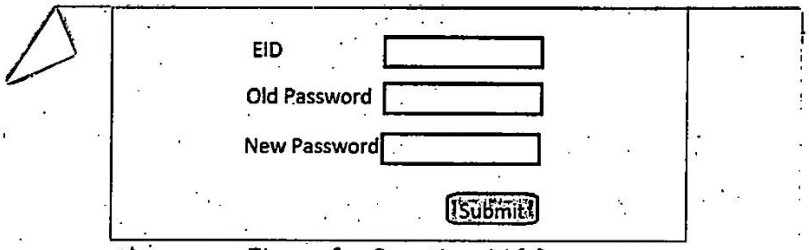


Figure for Question 11(a)

```
/* changepasswd.php */
<?php
    Seid = $_POST['EID'];
    $oldpwd = $_POST['OldPassword'];
    $newpwd = $_POST['NewPassword'];
    $conn = new mysqli("localhost","root",
"seedubuntu", "dbtest") ;
    $sql ="UPDATE employee
    SET password =' $newpwd'
    WHERE eid = $eid' and password ='
$oldpwd' ";
    $result = $conn->query($sql);
    $conn->close();
?>
```

Code for Question 11(a) and 11(b)

(b) Change the *changepasswd.php* file using prepared statement to prevent SQL injection like previous example. **(10)**

12. (a) Consider the following snapshot of a guest book in a sample site http://vulnerable.com. Suppose you are an attacker named Sammy (id=40). Now write a sample script in the Message box that can demonstrate all the damages XSS can cause. Suppose you know the following information about this site. **(15)**

- Id of the first paragraph (Please Sign Our Guestbook) is "pl"
- The URL of sending a friend request to a user with id 100 is http://vulnerable.com /action/friend/add?id=100.

Contd P/6

CSE 405

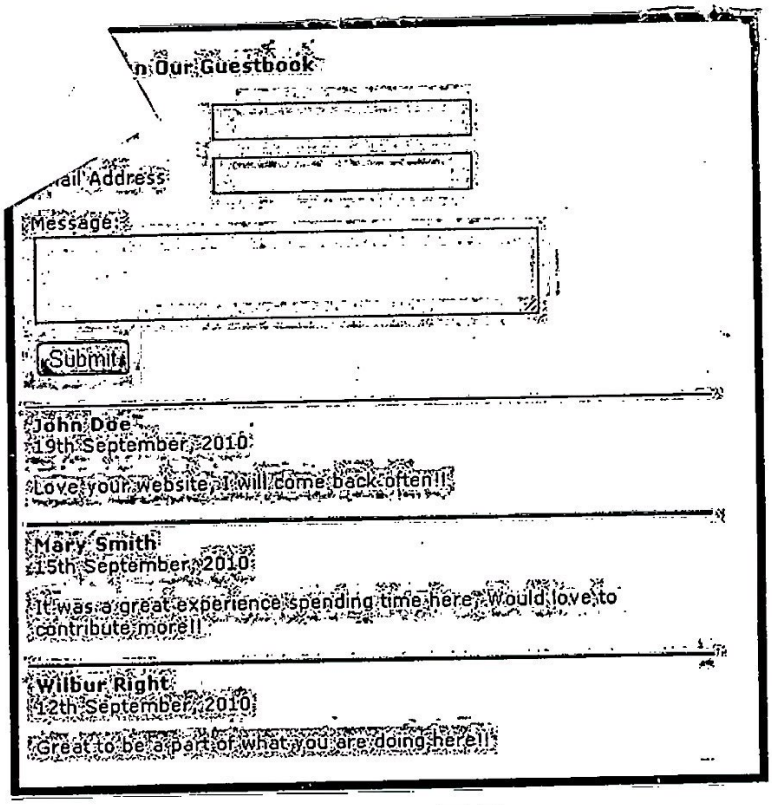


Figure for question 12(a)

13 Suppose Alice and Bob has started a one-time pad using Quantum Cryptography. Trudy as an intruder can read all the bits sent in both directions. Now complete the row c, d, e, g in following figure. **(15)**

Bit number	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	
Data	0	0	1	1	0	1	1	1	0	0	1	1	0	0	0	1	
(a)	↗	↗	↘	→	↕	→	↘	→	↗	↕	→	↘	↕	↕	↗	↗	What Alice sends
(b)	+	+	×	+	×	+	×	×	+	×	+	+	+	+	+	×	Bob's base
(c)																	What bob get
(d)																	Correct basis?
(e)																	One-time pad
(f)	×	+	×	+	×	×	×	+	×	+	×	+	×	+	×	+	Trudy's bases
(g)																	Trudy's pad

Figure for Question 13